



Weekly IT Security Brief (Official-source-first) | 2026-10-04 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-102490(2026-10-05), CVE-2026-102489(2026-10-05), CVE-2026-104286(2026-10-04). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Preparing governments for an era of interconnected cyber risk. According to this year's Microsoft Digital Defense Report, government agencies and services were the sector most impacted by cyber threats in 2026, accounting for 27% of observed...
- Threat trend #2: Insights from the 2026 Microsoft Digital Defense Report. Read highlights from the 2026 Microsoft Digital Defense Report, which reflects a security environment that continues to grow more interconnected. The post Insights from the 2026 Microso...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-102490

CVE Title	CVE-2026-102490 zammad/zammad Unknown Type
CVE Description	All versions of Zammad including the latest alpha enable the local zammad user to escalate privileges to root.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	zammad/zammad, docker/docker, linux/linux_kernel
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-05
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-102490

CVE-2026-102489

CVE Title	CVE-2026-102489 zammad/zammad Remote Code Execution
CVE Description	Zammad versions 6.3.0 to 6.5.4 are vulnerable a session hijack vulnerability that leads to remote code execution as the zammad user. The vulnerability is also present in version 7.0.0 to version 7.1.3, but not exploitable due to environment conditions.
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	zammad/zammad, docker/docker, linux/linux_kernel
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-05
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-102489

CVE-2026-104286

CVE Title	CVE-2026-104286 fortinet/fortimail Unknown Type
CVE Description	An improper limitation of a pathname to a restricted directory ('path traversal') vulnerability in Fortinet FortiMail 8.0.0 through 8.0.1, FortiMail 7.6.0 through 7.6.6, FortiMail 7.4.0 through 7.4.8, FortiMail 7.2.0 through 7.2.9 may allow an unauthenticated attacker to write arbitrary files on the underlying system via crafted HTTP or HTTPS requests.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	fortinet/fortimail
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-04
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-104286

CVE-2026-76504

CVE Title	CVE-2026-76504 cisco/catalyst_sd-wan_manager Unknown Type
CVE Description	A vulnerability in the API session-based authentication management of Cisco Catalyst SD-WAN Manager could allow an unauthenticated, remote attacker to access an affected system with privileges of the admin user.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	cisco/catalyst_sd-wan_manager
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-76504

CVE-2026-86950

CVE Title	CVE-2026-86950 apple/ipados Out-of-Bounds
CVE Description	An out-of-bounds write issue was addressed with improved bounds checking. This issue is fixed in iOS 26.7.1 and iPadOS 26.7.1, macOS Sequoia 15.8.1, macOS Tahoe 26.7.1. Processing a maliciously crafted file may lead to arbitrary code execution. Apple is aware of a report that this issue may have been exploited in an extremely sophisticated attack against specific targeted individuals on versions of iOS before iOS 27.
Root Cause	Memory-safety weakness can cause memory corruption or unintended control flow.
Exploitation Prerequisite	Victim must process malicious content (web page/file/packet).
Exploit Path	Delivery of malicious content -> memory fault trigger -> code execution / crash.
Affected Products	apple/ipados, apple/iphone_os, apple/macos
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-10-02
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-86950

Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-100739

CVE Title CVE-2026-100739 | 待核實 | SQL Injection

CVE Description A vulnerability was detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file viewresult.php. Performing a manipulation of the argument seno results in sql injection. Remote exploitation of the attack is possible. The exploit is now public and may be used. This product follows a rolling release approach for continuous delivery, so...

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-100739>

CVE-2026-100740

CVE Title CVE-2026-100740 | 待核實 | Out-of-Bounds

CVE Description A vulnerability was detected in D-Link DIR-895L A1_102b07. Impacted is the function tunnel_set_params of the file tunnel.c of the component L2TP Control Channel Parser. Performing a manipulation results in out-of-bounds write. The attack may be initiated remotely. The exploit is now public and may be used.

Affected Products 待核實

Risk Score 9.9 (CRITICAL)

Source <https://nvd.nist.gov/vuln/detail/CVE-2026-100740>

CVE-2025-71422

CVE Title CVE-2025-71422 | 待核實 | Unknown Type

CVE Description Contrast is a Kubernetes runtime for confidential containers. In versions before 1.12.1, the secure persistent volume feature is vulnerable to a malicious host supplying a crafted LUKS2 volume to a pod VM. LUKS2 volume metadata is not authenticated and, with cryptsetup versions prior to 2.8.1, a header specifying the null keyslot encryption algorithm (cipher_null-ecb) is accepted without error. Because the Contrast...

Affected Products 待核實

Risk Score 5.7 (MEDIUM)

Source <https://nvd.nist.gov/vuln/detail/CVE-2025-71422>

CVE-2025-71423

CVE Title CVE-2025-71423 | 待核實 | Unknown Type

CVE Description Edgeless Contrast is a confidential-computing runtime for Kubernetes. In versions 1.9.0 before 1.12.2, the initializer logs the full NewMeshCert response — which contains the workload secret — to standard output at INFO level. As a result, workload secrets are exposed to any Kubernetes user with get or list permission on pods/logs. Because workload secrets are used for encrypted storage and Vault integration, tho...

Affected Products 待核實

Risk Score 7.3 (HIGH)

Source <https://nvd.nist.gov/vuln/detail/CVE-2025-71423>



Report B: Threat Intelligence News (last 7 days)

Headline: Preparing governments for an era of interconnected cyber risk

Source	Microsoft Security Blog
Published	Thu, 01 Oct 2026 14:00:00 +0000
Key Takeaway	According to this year’s Microsoft Digital Defense Report, government agencies and services were the sector most impacted by cyber threats in 2026, accounting for 27% of observed activity, up from 17% in 2025. The post Preparing governments for an era of interconnected cyber risk appeared first on M Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blogs.microsoft.com/on-the-issues/2026/10/01/preparing-governments-for-an-era-of-interconnected-cyber-risk/

Headline: Insights from the 2026 Microsoft Digital Defense Report

Source	Microsoft Security Blog
Published	Thu, 01 Oct 2026 14:00:00 +0000
Key Takeaway	Read highlights from the 2026 Microsoft Digital Defense Report, which reflects a security environment that continues to grow more interconnected. The post Insights from the 2026 Microsoft Digital Defense Report appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/10/01/insights-from-the-2026-microsoft-digital-defense-report/

Headline: CISA Launches Cybersecurity Awareness Month: Securing the Next 250

Source	CISA News
Published	Thu, 01 Oct 26 12:00:00 +0000
Key Takeaway	CISA Launches Cybersecurity Awareness Month: Securing the Next 250 Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-launches-cybersecurity-awareness-month-securing-next-250

Headline: CISA Whitepaper Charts Path to Establishing and Maturing CVE Program Quality

Source	CISA News
Published	Wed, 23 Sep 26 12:00:00 +0000
Key Takeaway	CISA Whitepaper Charts Path to Establishing and Maturing CVE Program Quality Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-whitepaper-charts-path-establishing-and-maturing-cve-program-quality

Headline: Give yourself room to be human

Source Cisco Talos Blog

Published Thu, 01 Oct 2026 18:00:52 GMT

Key Takeaway In this week's edition, Amy reflects on the importance of prioritizing family and personal well-being over the pressure to remain constantly productive. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/give-yourself-room-to-be-human/>

Headline: The Fine Art of Frustrating the Adversary

Source	Cisco Talos Blog
Published	Thu, 01 Oct 2026 10:00:05 GMT
Key Takeaway	What really frustrates an adversary? Eight Cisco Talos researchers share practical ways to make their next move slower and riskier. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-fine-art-of-frustrating-the-adversary/

Headline: MI5 Says China’s MSS Funded Research Involving 100+ U.K.-Linked Academics

Source	The Hacker News
Published	Sat, 03 Oct 2026 20:08:46 +0530
Key Takeaway	The U.K.'s domestic intelligence and security agency has warned that more than 100 academics have helped China boost its intelligence gathering efforts on behalf of Beijing's state security service. In a "Security Service Espionage Alert" issued on September 30, 2026, MI5 said the "primary purpose o Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor ano...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/mi5-says-chinas-mss-funded-research.html

Headline: Warlock Exploits SharePoint Flaws to Disable Security Tools and Deploy Ransomware

Source	The Hacker News
Published	Sat, 03 Oct 2026 20:06:33 +0530
Key Takeaway	The suspected China-linked threat actor known as Warlock is still continuing to weaponize Microsoft SharePoint vulnerabilities, likely both old and new, in attacks targeting organizations in Portuguese- and Spanish-speaking countries. The activity, observed by the Symantec and Carbon Black Threat Hu Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/待核實
Technique	Ransomware
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/10/warlock-exploits-sharepoint-flaws-to.html

Headline: doxx.net Raises \$38 Million to Prevent AI Agent-on-the-Internet Misadventures

Source	SecurityWeek
Published	Sat, 03 Oct 2026 11:45:00 +0000
Key Takeaway	doxx.net’s new ADN platform prevents agentic misadventure while the agent is operating under the user’s authority. The post doxx.net Raises \$38 Million to Prevent AI Agent-on-the-Internet Misadventures appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/doxx-net-raises-38-million-to-prevent-ai-agent-on-the-internet-misadventures/

Headline: Fortra Patches Critical Vulnerabilities in BoKS

Source	SecurityWeek
Published	Sat, 03 Oct 2026 11:34:00 +0000
Key Takeaway	The bugs could lead to authentication bypass, shell command execution, and memory corruption. The post Fortra Patches Critical Vulnerabilities in BoKS appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/fortra-patches-critical-vulnerabilities-in-boks/

Headline: ShinyHunters hacker reportedly detained in Jordan, aiding FBI

Source	BleepingComputer
Published	Sat, 03 Oct 2026 15:09:38 -0400
Key Takeaway	A suspected ShinyHunters hacking group member known online as "Rey" has reportedly been detained in Jordan and is cooperating with the FBI to help locate other members of the extortion group. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.bleepingcomputer.com/news/security/shinyhunters-hacker-reportedly-detained-in-jordan-aiding-fbi/

Headline: Danish university DTU breach exposes data of up to 200,000 people

Source BleepingComputer

Published Sat, 03 Oct 2026 10:35:20 -0400

Key Takeaway The Technical University of Denmark (DTU) says information belonging to up to 200,000 users may have been exposed after hackers accessed its identity and access management system and downloaded a large amount of data. [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/danish-university-dtu-breach-exposes-data-of-up-to-200-000-people/>



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)